

WEBSIDIAN 신뢰·운영 부록

심사위원용 60초 요약

- **공개 데이터:** 기본 이슈 294건과 벤치마크 과제는 처음부터 작성한 완전 합성 데이터다.
- **현재 위치:** 개인이 구현한 실무 유사 POC이며 회사의 공식 제품·승인·도입·운영 사례가 아니다.
- **AI 책임:** 분석·테스트·파생 기억은 검토 초안이며 원문과 분리된다. 완료 판단과 업무 결정은 사람이 한다.
- **외부 전송:** 사용자가 AI 기능을 실행할 때 선별 문맥이 OpenRouter로 전송될 수 있어 실제 회사 자료는 현재 입력하지 않는다.
- **현재 통제:** 사용자 범위 저장, 원문 불변, 서버 근거 재수집, 인용·구획 검증, D1 호출 제한, 내용 없는 텔레메트리, source fallback을 구현했다.
- **운영 전 필수:** SSO·RBAC·자료 ACL·DLP·감사·보존/삭제·공급자 계약·백업/복구를 통과한 뒤 제한 파일럿으로 검증한다.

1. 현재 상태 선언

Websidian은 개인이 구현한 **실무 유사 POC**다. 회사의 공식 제품, 승인된 운영 서비스, 전사 도입 사례 또는 보안 검토를 완료한 시스템이 아니다. 기본 이슈 294건은 모두 합성 데이터이며 실제 고객, 임직원, 거래, 장애, 내부 시스템과 운영 문서를 사용하지 않았다.

공개된 벤치마크 수치는 합성 시나리오에서의 검색·경로 회수와 문서 순위 대리지표다. 실제 회사의 업무시간·비용·품질·장애 감소 성과가 아니다. 이 부록은 현재 구현된 통제와 운영 전에 필요한 통제를 구분해, POC를 완성된 운영 체계처럼 보이게 하지 않는 것을 목적으로 한다.

2. 주장 등급

등급	의미	이 제출물의 예
구현 사실	코드·데이터·테스트에서 직접 확인 가능	합성 이슈 294건, 완료 후보 251건, 2-hop 탐색, 사용자 범위 D1 저장, 텔레메트리 스키마
POC 관측값	동결된 합성 조건에서 재실행 가능	Recall@10, nDCG@10, 문서 순위, 함수 실행시간, 선택 문맥 문자수
미검증 가설	실제 사용자·운영 검증 전에는 성과로 주장하지 않음	현업 시간 절감, 장애 예방, 전사 정착, 장기 비용 절감
운영 전 요구사항	구현 또는 조직 승인 뒤에만 가능	SSO·팀 RBAC, 자료 ACL, 감사·보존, 공급자 계약, DLP, 백업·복구

발표와 문서의 모든 숫자는 이 네 등급 중 어디에 속하는지 식별할 수 있어야 한다. 예상효과를 관측값과 같은 표에 섞지 않는다.

3. 합성 데이터 경계

3.1 포함된 공개 데이터

- `data/issues.json`: 대표 24건과 배경 270건, 총 294건
- `data/github-issue-drafts.json`: 공개 GitHub 시연용 이슈 초안
- `data/github-bindings.json`: 대표 이슈와 공개 GitHub 예시의 연결 식별자
- `evidence/poc-benchmark/`: 합성 과제, qrels, 프로토콜과 결과

이슈 ID, 인물·팀, 날짜, 본문, 처리 결과, 자료 식별자와 관계는 모두 POC를 위해 만든 정보다. `code:/`, `doc:/`, `policy:/` 표시는 실제 사내 경로나 커밋이 아니다. 실제 항목과 우연히 유사할 수 있으나 실제 사건을 지칭하지 않는다.

3.2 포함되지 않은 데이터

- 실제 고객·계좌·거래·상담·주문 정보
- 실제 임직원의 개인정보와 평가 정보
- 실제 장애·보안사고·운영 일정
- 실제 저장소·서버·API·문서 경로와 인증정보
- 회사의 비공개 정책, 시스템 구조와 영업기밀

실제 자료를 단순 익명화해 공개 데이터로 바꾸는 방식도 사용하지 않았다. 익명화된 원문이 조직 구조나 사건 조합을 통해 재식별될 위험을 피하기 위해 처음부터 합성 시나리오로 작성했다.

3.3 런타임 사용자 데이터

사용자가 직접 만든 이슈와 GitHub에서 가져온 이슈는 합성 seed와 별개다. Websidian은 외부 콘텐츠의 공개 가능성, 보안 등급 또는 AI 전송 허가를 판정하지 않는다. 가져오기 권한이 있어도 외부 AI 처리 권한이 자동으로 생기는 것은 아니다. 현재 POC에는 실제 회사 자료를 입력하지 않는 것을 원칙으로 한다.

4. 외부 서비스와 데이터 흐름

브라우저

→ Sites 인증 게이트웨이

→ Websidian 서버 로직

- D1: 사용자별 이슈·파생 기억·내용 없는 AI 측정 로그
- GitHub: 사용자가 요청한 이슈·댓글의 단방향 읽기
- OpenRouter: 사용자가 실행한 분석·테스트·기억·임베딩 문맥

← 검증된 결과 또는 원문 기반 fallback

구성요소	담당 역할	하지 않는 일·남은 책임
Sites	POC 호스팅, 로그인 게이트웨이, 사용자 식별 헤더와 D1 바인딩	AI 판단을 생성하지 않는다. 공개 범위·가용성·약관과 운영 승인은 별도다.
D1	사용자별 overlay, 파생 기억·벡터, 호출 제한과 텔레메트리 저장	운영용 보존·삭제·백업·복구 정책은 아직 없다.
GitHub	지정 저장소의 이슈·댓글을 서버가 읽어 단방향 스냅샷으로 변환	원본 이슈를 닫거나 수정하지 않는다. 접근권한·콘텐츠 사용권한은 사용자가 확인한다.

구성요소	담당 역할	하지 않는 일·남은 책임
OpenRouter	지정 모델 요청을 외부 모델 제공자에게 중계	결과의 사실성·규제 적합성을 보증하지 않는다. 실제 제공자·가격·처리 위치는 호출 시점 정책의 영향을 받는다.

GitHub에서 가져온 콘텐츠가 관련 이력으로 선택되면 사용자의 AI 기능 실행 시 일부 문맥이 OpenRouter로 전송될 수 있다. 공개 저장소도 외부 AI 처리 조건과 저작권을 별도로 확인해야 한다.

5. AI 사용과 책임 경계

5.1 개발 과정

아이디어 정리, 조사, UI 설계, 코드 작성, 테스트와 문서화에 ChatGPT·Codex 계열 AI가 보조 도구로 사용됐다. 기능 범위 선택, 코드 실행, 수정, 검증, 제출과 공개 결정은 프로젝트 작성자의 책임이다. AI 보조 사실이 코드의 정확성·독창성·보안성 또는 제3자 권리 침해를 보증하지 않는다.

5.2 실행 중 AI

기능	현재 요청 모델	AI 출력의 위치
이슈 분석	OpenRouter의 <code>openai/gpt-5.6-luna</code>	선택 이슈 관점의 근거 기반 분석 초안
테스트 케이스	OpenRouter의 <code>openai/gpt-5.6-luna</code>	과거 롤백·타팀 변경·회귀 조건을 반영한 테스트 후보
파생 기억 컴파일	OpenRouter의 <code>openai/gpt-5.6-luna</code>	canonical 이슈와 분리된 검색용 파생물
의미 색인	OpenRouter의 <code>qwen/qwen3-embedding-8b</code>	검색용 벡터, 일반 이슈 응답으로 보내지 않음

외부 AI는 서버 설정이 존재하고 사용자가 해당 기능을 실행할 때만 생성·임베딩 요청을 받는다. 모델 ID와 지원 파라미터를 확인하고, 생성 응답은 JSON을 강제하지 않고 평문 구획으로 받는다. 화면용 구획이 일부 깨지면 정상 구획은 카드로 보이고 깨진 부분은 원문으로 남는다. 파생 기억은 더 엄격히 검증하며 불완전한 생성물을 확정하지 않는다.

분석은 근거를 사람이 읽기 쉬운 원인 후보·위험·처리 방향으로 재구성하는 초안이다. 테스트 케이스는 현재 구현의 정상 경로만 반복하는 대신 연결된 과거 기록에서 재시도, 경계값, 롤백, 공유 모듈과 타팀 변경의 사이드 조건을 끌어오는 것을 목표로 한다. 이는 유용성 가설이며, 생성된 테스트가 완전하거나 결함을 예방한다는 보장은 아니다.

5.3 사람에게 남는 책임

- 이슈의 사실 확인과 접근 권한 판단
- 관련 이력이 원인인지 단순 유사성인지 확인
- 처리 방향, 배포, 테스트와 리스크 수용 결정
- 생성된 테스트 조건의 실행 가능성·커버리지·중복 여부 검토
- 완료 기록의 정확성, 정정과 재개방
- AI 결과를 근거 원문과 대조하고 잘못된 결과를 배제

AI는 원본 이슈의 제목·본문·처리 이력을 바꾸지 않고 이슈를 자동 완료하지 않는다. GitHub 원본도 수정하지 않는다. 인용 ID 검증은 제공된 근거 범위 안의 ID인지만 확인하며, 문장 자체의 진실성이나 인과관계를 보증하지 않는다.

6. 외부 AI 데이터 처리 설정

- 생성 요청은 OpenRouter 제공자 설정에 `data_collection: deny`를 전달한다.

- 임베딩 요청은 `data_collection: deny`, `zdr: true` 와 OpenRouter 캐시 비활성화를 요청한다.
- API 키는 서버 비밀로만 설정하고 브라우저·소스·문서·로그에 저장하지 않는다.
- 설정 플래그는 애플리케이션의 요청 조건이며, 회사 보안 승인·법적 계약·데이터 처리계약 또는 모든 하위 제공자의 준수를 독립적으로 보증하지 않는다.

실제 회사 데이터를 사용하려면 OpenRouter와 하위 제공자의 보존·재학습·처리 위치·사고 통지 조건을 계약 및 회사 정책으로 확인해야 한다. 그 전에는 합성 데이터만 사용한다.

7. 현재 구현된 통제

통제	현재 구현
사용자 범위	Sites가 주입·덮어쓰는 사용자 식별자를 기준으로 이슈와 파생 데이터를 D1에서 분리
변경 요청	같은 origin의 JSON 요청, 입력 길이·크기 제한
동시성	신규 생성 멍등성, revision CAS를 통한 stale·중복 완료 거부
근거 범위	서버가 접근 가능한 완료 이력만 다시 수집; 클라이언트 임의 시스템 프롬프트·모델·원문을 사용하지 않음
프롬프트 인젝션 완화	이슈와 외부 콘텐츠를 비신뢰 데이터로 선언하고 내부 지시·도구 호출을 금지
원문 보존	canonical 이슈와 AI 분석·파생 기억·벡터를 분리
출력 처리	허용된 인용 ID와 평문 구획 검증; 부분·실패 상태와 원문 fallback 보존
외부 쓰기	GitHub 가져오기는 읽기 전용이며 원본 상태를 변경하지 않음
호출 보호	사용자별·기능별 D1 공통 요청 제한, 동일 Worker isolate 안의 동일 임베딩 중복 실행 방지, 제한 시간과 출력 상한
응답 캐시	API 응답에 <code>private, no-store</code> 적용
AI 텔레메트리	원문·프롬프트·결과·키·이메일 없이 모델·버전·문자수·토큰·시간·비용·상태 기록; 사용자 범위 CSV

이 목록은 현재 코드의 POC 방어선이지 완전한 보안 또는 규제 준수 인증이 아니다. Sites 인증 헤더를 신뢰할 수 없는 별도 Worker origin으로 애플리케이션을 우회 노출해서는 안 된다.

8. 텔레메트리의 개인정보 경계

`websidian_llm_runs` 는 다음 내용을 저장하지 않는다.

- 이슈 본문과 관련 이력 원문
- 시스템·사용자 프롬프트
- 생성된 분석·테스트·기억 내용
- API 키, 이메일과 로그인 원문 ID

기록하는 항목은 모델 ID, 프롬프트 버전, 기능 lane, 근거 수, 입력 문자수, 시간, 토큰, 제공자 비용, 요청 ID, 시도 횟수, 상태와 오류 단계다. 소유자 값은 고정 namespace와 함께 SHA-256으로 범위화한다. 합성 POC의 호출 연결을 위해 이슈 ID는 남는다.

내용을 저장하지 않는 설계는 노출 면적을 줄이지만 익명성을 보증하지 않는다. 모델·시간·이슈 ID 조합도 사용 패턴을 드러낼 수 있다. 현재 자동 삭제 정책이 없으므로 운영 전 보존기간, 접근권한, 삭제와 감사 정책을 정해야 한다.

9. 현재 남은 위험

위험	현재 완화	운영 전 필수 조치
실제 민감정보 입력	합성 seed와 명시적 고지	DLP·분류·마스킹, 입력 차단, 사용자 교육
권한이 다른 기록의 연결	사용자별 D1 범위	회사 SSO, 조직·프로젝트 RBAC, 자료별 ACL 상속
LLM 환각·잘못된 인과	인용 ID·구획 검증, 사실/추정 분리, 원문 표시	품질 평가, 고위험 결과 승인, 정정·재개방 절차
프롬프트 인젝션	비신뢰 데이터 지시와 도구 호출 금지	적대적 테스트, 입력 정규화, 정책 게이트
외부 제공자 보존·중단	데이터 수집 거부 요청, source fallback	공급자 계약·DPA, 처리지역 검토, 장애·전환 런북
키 유출·과금 폭증	서버 비밀과 호출 제한	조직별 예산, 키 회전·폐기, 이상 사용 경보
잘못된 GitHub 권한	서버 토큰, 읽기 전용 스냅샷	최소권한 앱, 저장소 allowlist, 권한 철회 동기화
데이터 장기 잔존	사용자 범위 저장	보존·삭제·퇴직 처리, 백업·복구와 파기 검증
POC 규모 과적합	294건·3과제 범위와 실패 공개	대규모·다부서 데이터, 독립 qrels, 반복사용 파일럿
공개 소스 오해	무라이선스 고지	권리 귀속·라이선스·제3자 notice 검토 후 명확한 조건 부여

10. 운영 전 게이트

Gate 0 · 공개 심사 데모

- 합성 데이터만 포함
- 합성 이슈 데이터에 실제 회사명·고객명·시스템명·내부 URL·경로 없음. 발표자가 공개를 승인한 본인 소속·직함·성명 표기는 예외
- `.env`, 키, 토큰, 쿠키와 로컬 경로 제거
- Git 전체 이력과 ZIP·영상·빌드 산출물 secret scan
- 외부 쓰기 차단, 대표 시나리오 초기화와 장애용 녹화본 준비
- 무로그인 링크의 공개 범위·종료 시점 확인

Gate 1 · 폐쇄형 사용자 파일럿

- 실제 데이터 없이 합성 시나리오로 먼저 진행
- 참가자·과제·반복·비교 기준과 측정식을 사전 고정
- 사용자 동의, 로그 접근자와 보존기간 확정
- AI 호출비용·TTFT·토큰·오류·폴백 기록 확인
- 결과를 실제 운영 성과가 아닌 파일럿 관측값으로 보고

Gate 2 · 승인된 사내 데이터 연결

- 회사 SSO, 팀 RBAC와 원본 시스템의 ACL 상속
- 수집 전 데이터 분류와 마스킹, 외부 AI 전송 허용 기준
- OpenRouter·하위 제공자·Sites·D1·GitHub 보안·법무·구매 검토
- 감사로그, 기억 정정·재개방, 보존·삭제·백업·복구
- 제품·현업·보안·데이터·운영 책임자 RACI

Gate 3 · 운영 확대

- 대규모 성능·비용·품질·권한 회귀 시험
- 조직·사용자별 비용 상한과 이상징후 경보
- 공급자 장애·모델 변경·색인 재생성 런북
- 월별 품질·비용·오류·정정 지표와 중단 기준
- 타 부서·계열사는 별도 적합성·권한 검토 후 단계적으로 연결

현재 상태는 Gate 0용 POC다. Gate 1~3 완료를 전제로 말하거나 전사 도입이 준비됐다고 주장하지 않는다.

11. 공개 소스와 라이선스 경계

현재 저장소에는 **LICENSE**가 없다. 작성자·회사·제3자 간 권리 귀속, 고용 관계에서의 권리, 참고 자료와 의존성 조건을 확인하기 전에 임의의 MIT·Apache 등 라이선스를 부여하지 않기 위해서다.

따라서 다음을 구분한다.

- 공개 저장소: 심사·검토·재현을 위해 소스를 열람하고 저장소의 실행 절차를 확인할 수 있음
- 오픈소스 허락: 사용·수정·재배포 조건을 명시적 라이선스로 부여하는 행위

현재 공개는 첫 번째이며 두 번째가 아니다. 공개적으로 접근 가능하다는 이유만으로 코드를 자유롭게 사용·수정·재배포할 수 있다고 해석해서는 안 된다. 패키지와 외부 서비스는 각 제공자의 라이선스·약관을 별도로 따른다.

제출 전에는 생성형 AI, OpenRouter, GitHub API, Sites와 주요 패키지를 기술·라이선스 명세에 적고, 소스 공개 범위와 참고 구현의 권리를 확인한다. 권리 확인이 완료된 뒤 프로젝트 라이선스를 선택하거나 공개 범위를 조정한다.

12. 제출용 고지문

Websidian은 개인이 구현한 실무 유사 POC이며 회사의 공식 제품이나 도입 사례가 아닙니다. 기본 이슈 294건과 공개 데모는 전부 합성 데이터로 구성했고 실제 고객정보·개인정보·운영 이력·내부 시스템 자료를 사용하지 않았습니다. 정량 결과는 명시된 합성 시나리오와 실행 조건에서의 검색 순위·문맥 선별 관측값이며 실제 업무시간 또는 회사 비용 절감 실적과 구분됩니다. 개발 과정에는 생성형 AI를 보조 도구로 사용했고, 실행 중 AI 기능은 사용자가 요청할 때 OpenRouter를 통해 외부 모델을 호출합니다. AI 결과는 원문을 수정하거나 업무를 자동 확정하지 않으며 최종 판단과 검증은 사용자 책임입니다. 현재 저장소에는 권리 귀속과 제3자 조건 확인 전이므로 별도 **LICENSE**를 부여하지 않았습니다.